Instructions. There are **85 total points**. Answer only inside the provided circles, boxes, figures, or tables, and do not exceed box boundaries. Bubbles must be filled out completely: ● is correct, ⊘ ⊙ ⊗ are incorrect. **Permitted materials:** one 8.5x11-inch double-sided note sheet, typed or handwritten. No books, printouts, or other notes, and no electronic devices of any kind (including phones, laptops, tablets, smartwatches, and calculators).

Write your full name here to acknowledge these instructions:

Threat Models and Foundations

1. [4 points]: An AI agent that posts class announcements holds a stored Slack token. An attacker obtains the token and posts "The midterm is canceled" to the course channel. Give the threat model, one item per box: the **asset** harmed (not the token itself), the **property** violated, a plausible **adversary** and their motive, and the **capability** the attacker needed.

Asset:

Property:

Adversary:

Capability:

2. [3 points]: Every security system has a *root of trust*: the point where the chain of trust stops and you simply accept something. For each, name the key or certificate that is accepted without being checked, and who ships it.

A browser's TLS connection to a web site:

DNSSEC validation of a DNS answer:

RPKI's check that an AS may announce a prefix:

3. [3 points]: A payments startup discovers that a production API key committed to a public GitHub repository eight months ago has been used by an outsider to issue refunds. Among the failure modes in Anderson's "Why Cryptosystems Fail," this is primarily a failure of: (Select the best answer.)

◯ The cryptographic algorithm protecting the key

◯ Key management and operational procedure

◯ A remote software vulnerability in the API server

◯ A fake terminal or skimmer

◯ Usability of the customer-facing product

4. [4 points]: Case study. In 2012 an anonymous researcher logged into hundreds of thousands of home routers that still had their factory default passwords, used them to scan the entire Internet, and published the data set (the "Carna botnet"). The owners were never asked. Today a graduate student proposes to use the published data set to study how address usage has changed since 2012. Using *respect for persons*, give one argument **against** the original collection; using *beneficence*, give one argument **for** the reuse today.

Against the collection (respect for persons):

For the reuse (beneficence):

Key Management and Public Key Infrastructure

5. [4 points]: Which of the following statements are true? (Select all that apply.)

◯ A browser uses asymmetric cryptography to establish a symmetric key, which then encrypts the traffic

◯ To send Bob a message only he can read, Alice encrypts it with Bob's public key

◯ To sign a message so others can verify it came from her, Alice uses Bob's public key

◯ A certificate is a signed statement binding an identity to a public key, with an issuer and validity period

◯ Integrity means that only authorized parties can read a message

6. [4 points]: The first time you connect to a new server with SSH, the client shows a key fingerprint and asks whether to trust it. Explain how Mallory, on the network path, mounts a man-in-the-middle attack on that first connection, and what a careful user must do to defeat it.

(Answer inside the box)

7. [4 points]: In Assignment 1 you captured your own HTTPS traffic with Wireshark and served your site with a self-signed certificate.

(a) Even though the payload was encrypted, name **two** things an on-path eavesdropper could still learn from an HTTPS connection like the one you captured.

(b) The browser warned about your self-signed certificate until you took one step. What was it, and what could someone who performed that same step on your laptop without your knowledge then do to your *other* HTTPS traffic?

8. [3 points]: Alice posts her public key in the course Slack channel so people can send her encrypted mail. This solves the key-distribution problem for anyone who wants to write to her. ◯ Yes ◯ No Explain why or why not.

(Answer inside the box)

Initials: ____

Authentication and Access Control

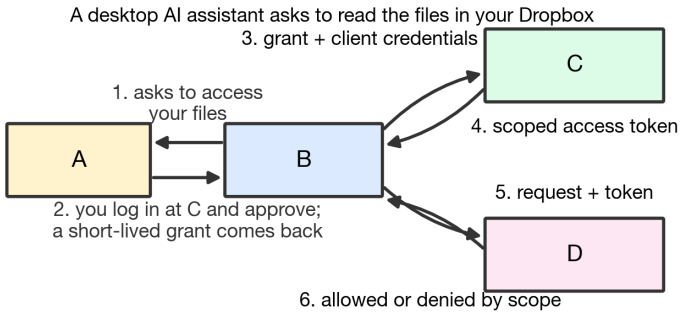
9. [4 points]: A desktop AI assistant asks to read the files in your Dropbox. The diagram shows the OAuth flow between four parties, A through D. OAuth names four roles: **resource owner**, **client**, **authorization server**, and **resource server**. Write the letter of the party that plays each role.

Resource owner: ____

Client: ____

Authorization server: ____

Resource server: ____



10. [3 points]: The agent that posts the class agenda presents a token to Slack, which checks the token and then lets it post in one channel but not delete messages. Which statements use the right term? (Select all that apply.)

◯ Presenting the token and having Slack verify it is *authentication*

◯ Presenting the token is *authorization*; checking it is *identification*

◯ Allowing posting but not deletion is *authorization*, enforced by access control

◯ Allowing posting but not deletion is *authentication*

◯ Recording that the agent posted at 3:05 pm is *logging*, which supports accountability

11. [3 points]: A budgeting app offers to track your spending if you give it your username and password for your bank's web site.

(a) Explain why this violates least privilege.

(Answer inside the box)

(b) Describe the narrow OAuth scope the bank should grant instead, as **who** (subject) may do **what** (verb) to **which data** (object).

Subject: ____ Verb: ____ Object: ____

Denial of Service

12. [4 points]: To stop a denial-of-service attack coming from one region, campus IT installs a firewall at the edge of the network that inspects every incoming connection and drops the attack traffic. Deploying the firewall has introduced a **new** denial-of-service vulnerability. ◯ Yes ◯ No Explain why or why not.

(Answer inside the box)

13. [4 points]: A new chat service allocates a 64 KB message buffer for every connection request the moment it arrives, before the client has sent anything else. Describe one way an attacker exploits this, and redesign the protocol in the spirit of SYN cookies so that the attack no longer works. A sentence or two of design is enough; no cryptographic detail is needed.

(Answer inside the box)

Routing Security

14. [2 points]: YouTube announces its addresses as a /22. Pakistan Telecom, intending to block YouTube inside Pakistan, announces two /24s covering the same space, and the announcement leaks to the whole Internet. Why did the world's YouTube traffic go to Pakistan? (Select the best answer.)

◯ Pakistan Telecom's AS path was shorter

◯ Routers prefer the more specific (longer) prefix, so the /24s won over the /22

◯ YouTube's RPKI certificate had expired

◯ Pakistan Telecom signed its announcement with BGPsec

15. [3 points]: Name **two** different things an attacker can do with someone else's addresses or traffic once a hijacked announcement is believed.

(Answer inside the box)

16. [4 points]: In BGPsec, each AS signs an attestation covering the AS path so far **and the AS it is sending the announcement to**. AS 160 originates a prefix and announces it to AS 174, which announces it to AS 15169. Suppose each AS signed the path so far but **not** the AS it was sending the announcement to. What could a dishonest AS 15169 announce to its own neighbors that would still pass validation, and why does 160's signature naming 174 prevent it?

(Answer inside the box)

Web Security

17. [3 points]: A page is loaded from `https://www.cs.uchicago.edu/courses`. Which of the following share its **origin** under the same-origin policy? (Select all that apply.)

◯ `https://www.cs.uchicago.edu/people`

◯ `http://www.cs.uchicago.edu/courses`

◯ `https://cs.uchicago.edu/courses`

◯ `https://www.cs.uchicago.edu/courses?term=autumn`

◯ A script the page loads from `https://cdn.example.com/jquery.js` runs in the page's origin

18. [3 points]: A web application runs the pseudocode
`run_shell("ls " + request.parameter("dir"))`
when a user requests a directory listing. What class of vulnerability is this, and what would an attacker put in the `dir` parameter to make the server run a command of the attacker's choosing? (An English description of the value is fine.)

(Answer inside the box)

19. [3 points]: A discussion forum displays each comment exactly as the author typed it, and a user posts a comment containing a `<script>` tag. Is this ◯ reflected or ◯ stored cross-site scripting? Why does the same-origin policy not protect the forum's other users?

(Answer inside the box)

20. [3 points]: You are logged in to your bank in one tab and visit a page showing a picture of a muffin in another.
(a) What kind of attack can the muffin page mount against your bank account, and why does it work?

(Answer inside the box)

(b) Name one defense that stops it:

Web Privacy

21. [3 points]: `nytimes.com` and `walmart.com` both embed a script from `tracker.example`. Explain how `tracker.example` learns that the same person visited both sites.

(Answer inside the box)

22. [3 points]: You are not signed in to any account, you have deleted all your cookies, and you use a private-browsing window. A tracking script embedded on the sites you visit can still recognize that your visits come from the same browser. ◯ Yes ◯ No Explain why or why not.

(Answer inside the box)

Initials: ____

DNS Security and Privacy

23. [3 points]: Which of the following statements are true? (Select all that apply.)

◯ DNSSEC provides confidentiality: an eavesdropper cannot see which names you look up

◯ Encryption provides confidentiality; signatures provide integrity

◯ A browser cannot resolve names itself; every lookup must go through the operating system's stub resolver

◯ With Oblivious DNS, no single server sees both your address and your query

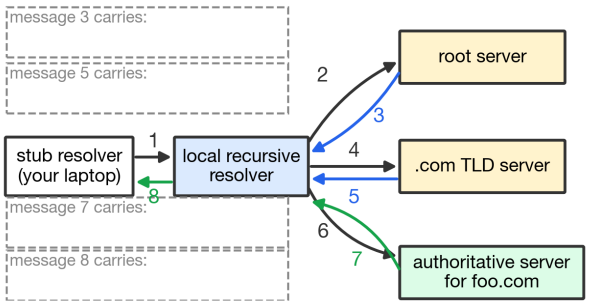
◯ DNS-over-HTTPS moves trust from your network operator to the resolver provider rather than eliminating it

24. [3 points]:

The diagram shows a lookup of `www.foo.com` with nothing cached.

(a) In each dashed box, label message 3, 5, 7, or 8 with **R** if it is a referral to another server or **A** if it is an answer carrying the record.

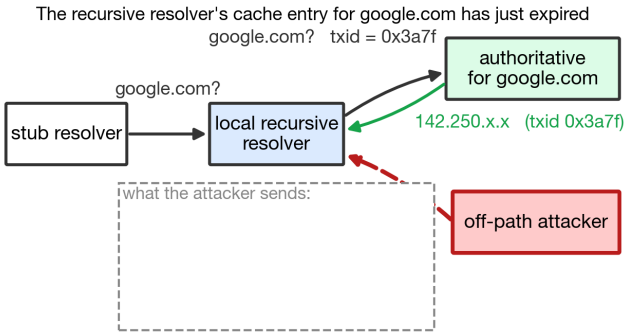
(b) Draw a box around the link (both directions) that DNS-over-HTTPS encrypts.



25. [3 points]:

The resolver's cache entry for `google.com` has expired; it re-queries the authoritative server with transaction ID `0x3a7f`, which the **off-path** attacker cannot see. In the dashed box, write what the attacker sends (its content, and how many); below, explain in one sentence why it works.

(Answer inside the box)



Course Feedback

26. [1 point]: Interest (1=Boring!; 10=Amazing!): ____ Difficulty (1=Too easy; 10=Too hard): ____

27. [1 point]: (a) One thing you liked about the course so far. (b) One suggestion for improvement:

(Answer inside the box)